

한국남동발전(주) 상임감사위원회

주의·개선요구

【05】

제 목 용역사업 정보보안 강화대책 이행관리 미흡

관 련 부 서 ●●처 * * 실

조 치 부 서 ●●처 * * 실

내 용

1. 업무 개요

●●처 * * 실은 2015년 에너지 공공기관 정보보안 강화대책 후속조치로 용역사업 보안관리 강화를 위해 용역사업 계약 체결 시 보안준수 특약체결 의무화, ‘보안성검토’ 대상사업 확대, 보안점검 이행 여부 확인 등 강화 조항을 반영하여 2015. 7. 13. 부로 「정보보호규정」을 개정하였다.

2. 관계 법령(사규) 및 판단기준

우리 회사 「정보보호규정」 제19조(용역업체 보안) 제2항에 따르면 용역 수행부서의 부서장은 용역업체와 계약 체결 시 사업수행 계약서와 별도로 비밀정보의 범위, 보안준수사항, 위반 시 민·형사상 책임, 자료의 반환 등이 포함된 보안준수 특수계약을 체결해야 한다고 되어 있고, 같은 조 제3항에 따르면 용역 수행부서의 부서장은 용역사업 추진 시 사업 계획수립부터 완료단계까지 사업 진행단계별로 보안대책을 수립·시행하여야 한다고 되어 있다.

그리고 같은 규정 제13조(보안성검토) 제1항에 따르면 처(실) 및 사업소장은 신규 ‘정보화사업’(정보화설비 구매·개발·구축·유지보수)이나 증설 등 추가 ‘정보화사업’, 용역사업, 사내망과 네트워크 연결을 요하는 신규 발전사업, ICT기술을 활용한 연구 과제 시행 시, 개인정보처리 위탁 시 자체 보안대책을 강구하고, 적절성 확인을 위하여 관련 사업 계획단계에서(사업 공고 전) 회사 정보보호 담당자와 협의하에 산업통상자원부장관을 경유하여 국가정보원장에게 보안성 검토를 의뢰하여야 한다고 되어 있고, 같은 조 제2항에 따르면 보안성 검토의 대상, 절차, 제출자료 목록, 보안대책에 포함해야 할 사항 등 구체적인 내용은 「정보보호 업무처리 절차서」에 정한다고 되어 있다.

우리 회사 「정보보호 업무처리 절차서」 1.5.나.에서는 회사 정보보호 담당자의 임무를 (1) 정보보호 정책 및 세부계획 수립·시행, (2) 자체 정보보호 관련 규정·지침 등 제·개정, (3) 보안협의회에 정보보안분야 안전 심의 주관, (4) 정보보호 업무 지도·감독 및 심사 분석 등으로 정하고 있다.

또한 우리 회사 「사규관리규정」 제6조(재검토기한의 설정) 제2항에 따르면 업무주관부서장은 사규의 재검토기한이나 존속기한이 만료되기 전에 관련 법령이나 업무현실의 변화 등을 검토하여 사규를 개정하거나 폐지하는 등의 조치를 하여야 하고, 같은 규정 제23조(사규정비) 제1항에 따르면 과도한 규제, 불합리한 내용·절차 등을 전반적으로 정비할 필요가 있거나 기타 업무효율 향상을 위해 필요한 경우 사규정비를 추진하도록 되어 있다.

따라서 용역사업 수행부서의 장은 용역사업 추진 시 보안관리 강화를 위해 ‘보안준수 특수계약’을 체결해야 하고, ‘보안성검토’ 대상은 사업 계획단계에서(사업 공고 전) 회사 정보보호 담당자와 협의하여 중앙부처에 ‘보안성검토’가 의뢰되어야 하며 회사 정보보호 담당자는 이를 지도하고 감독하여야 한다.

또한 정보보호 담당부서는 「정보보호규정」, 「정보보호 업무처리 절차서」의 내용이 현실에 맞게 정비할 필요가 있는 경우 또는 기타 업무효율 향상을 위해 필요한 경우에는 규정의 타당성을 검토하여 개선 등의 조치를 취하여야 한다.

3. 감사결과 확인된 문제점

가. ‘보안준수 특수계약’ 체결에 대한 지도·감독 미흡

그런데 이번 성과감사(2024. 10. 14. ~ 10. 25.)를 통해 전사 용역사업에 대한 ‘보안준수 특수계약’ 의뢰 여부를 확인해 본 결과, 용역 계약의뢰 총 x건 중 x건은 용역수행부서에서 ‘보안준수 특수계약’ 비대상으로 계약을 의뢰하고 있음을 확인하였다.

그 원인을 살펴보니 2014년 발생한 공공기관 사이버테러 관련 산업부에서 “에너지 공공기관 정보보안 체제 강화방안” 공표(‘15. 2. 12.) 이후, 기존 ‘정보화 사업’ 용역에만 시행되었던 ‘보안준수 특수계약’ 및 ‘보안성검토’ 대상을 용역사업 전체로 확대하면서 지속적인 지도와 점검이 이루어지지 않아 용역사업 시행부서에서는 해당 규정을 제대로 인지하지 못하고 있었다.

실제 「정보보호규정」 개정(‘15. 7. 13.) 이후, 문서번호 보안(**)-***** “용역사

업 및 정보화사업 시행 시 필수 준수사항 알림” 공문을 제외하고는 본사 차원에서 그 필요성에 대해 강조하거나 점검한 사례를 찾아볼 수가 없었다.

계약 체결 시 용역사업 시행부서와 계약부서가 교차 점검하여 본사에서는 총 x건 중 x건을 ‘보안준수 특수계약’ 대상으로 인지하여 용역계약서에 포함하였지만, 사업소에서는 총 x건 중 단 x건만 ‘보안준수 특수계약’ 수정·반영하고 있어서 본사를 제외하고는 교차 점검이 제대로 이루어지지 않고 있음을 확인하였다.

따라서 정보의 유출 등 수많은 보안 위협으로부터 중요 정보자산의 손실 등 용역업체에서 우리 회사 보안정책을 위반하였을 경우 위반자에 대한 행정조치, 위약금 부과 등 제재할 수 있는 객관적 근거를 마련하지 못하는 결과를 초래하였다.

나. 용역사업 중 ‘보안성검토’ 대상 명확화 필요

※ ※ 실은 ‘보안성검토’ 대상을 기존 ‘정보화사업’ 용역에서 모든 용역사업으로 확대 운영한다고 하였지만 감사대상기간(’21. 1. 1. ~ ’24. 9. 30.) ‘보안성검토’ 현황을 확인해 본 결과, 감사대상기간 정보보호 심의위원회 검토 안건은 총 x건 이었고 그 중 용역사업에 대한 안건은 총 x건으로 일반 용역사업이 아닌 모두 ‘정보화사업’ 용역에 해당하는 것을 확인하였다.

또한 사업소에서는 일반 용역사업은 제외하고 정보화 관련 용역사업만이 ‘보안성검토’의 대상임을 공지하고 사규와 다르게 운영되고 용역사업 시행부서에서도 혼란을 겪고 있다.

그 원인을 살펴보니 용역 중에는 “출퇴근버스 임차용역”, “유연탄 및 석회석

홀수검정 용역” 등 사업소 단순 현장 업무나 발전설비의 각종 시험 용역이 다수 포함되어 있고 해당 용역에 대해 사업소 용역 시행부서나 ICT 담당부서에서도 ‘보안성검토’ 및 ‘보안준수 특수계약’ 체결의 필요성에 대해 공감하지 못하고 있었다.

따라서 정보보호 담당부서는 관련 규정의 타당성을 재검토하고 효과적인 업무처리를 위해 그 대상을 명확히 하는 등 이를 개선할 필요가 있다.

관계부서 의견

이에 대하여 관계부서에서는 ‘보안준수 특수계약’ 의뢰 현황을 확인하고 개선 방안을 마련하겠다는 의견과 ‘보안성검토’ 대상을 명확하게 구분하여 사규와 실제 운영상의 불일치한 점이 발생하지 않도록 개선하겠다는 취지의 의견을 제시하였다.

조치할 사항 ●●처장은 ① 용역계약 시 ‘보안준수 특수계약’ 의무화 등 내부통제 대상 확대 및 강화 시에는 반드시 전 직원이 명확하게 인지하고 이행할 수 있도록 지속적인 지도와 감독을 강화하여 주시기 바라며, (주의)

② 「정보보호규정」, 「정보보호 업무처리 절차서」 등 ‘보안준수 특수계약’ 및 ‘보안성검토’ 대상을 재검토하고 그 대상을 명확히 구분할 수 있도록 관련 규정과 절차서를 개정하시기 바랍니다. (개선)